HealthConnect — Technical Context

Platform Architecture

```
┌──────────────────────────────────────────────────────────────────────┐
│                          CLIENT LAYER                                 │
│                                                                       │
│   ┌──────────────────────┐          ┌──────────────────────────────┐  │
│   │   Patient Web App    │          │   Clinician / Admin Portal   │  │
│   │   (React 18, PWA)    │          │   (React 18, role-gated)     │  │
│   └──────────────────────┘          └──────────────────────────────┘  │
│               │                                   │                   │
│               │  HTTPS / WebSocket                │                   │
└───────────────┼───────────────────────────────────┼───────────────────┘
                │                                   │
┌───────────────▼───────────────────────────────────▼───────────────────┐
│                        API GATEWAY (AWS API Gateway)                  │
│   • JWT validation (Cognito)   • Rate limiting   • WAF rules          │
│   • Request routing            • Usage plans     • Audit header inject│
└──────┬──────────┬──────────────┬──────────────┬────────────┬──────────┘
       │          │              │              │            │
┌──────▼──┐  ┌────▼─────┐  ┌─────▼────┐  ┌────▼─────┐  ┌────▼─────┐
│  Auth   │  │Appoint-  │  │ Messaging│  │  FHIR    │  │Notif-    │
│ Service │  │ment Svc  │  │ Service  │  │ Adapter  │  │ication   │
│         │  │          │  │          │  │          │  │ Service  │
│Cognito  │  │PostgreSQL│  │PostgreSQL│  │Epic EHR  │  │Twilio /  │
│+ Lambda │  │+ Lambda  │  │+ Lambda  │  │↔ FHIR R4 │  │SendGrid  │
└─────────┘  └──────────┘  └──────────┘  └──────────┘  └──────────┘
       │          │              │              │            │
┌──────▼──────────▼──────────────▼──────────────▼────────────▼──────────┐
│                    INTERNAL EVENT BUS (AWS EventBridge)               │
│   • appointment.booked   • appointment.cancelled  • message.received  │
│   • lab.result.ready     • prescription.requested • session.expired   │
└──────────────────────────────────────────────────────────────────────┘
                                      │
┌─────────────────────────────────────▼────────────────────────────────┐
│                        EXTERNAL INTEGRATIONS                          │
│                                                                       │
│   ┌──────────────┐  ┌──────────────┐  ┌──────────────┐  ┌──────────┐ │
│   │ Epic EHR     │  │ Doxy.me      │  │ Stripe       │  │Apple Health│ │
│   │ FHIR R4      │  │ (Telehealth) │  │ (Payments)   │  │Google Fit  │ │
│   └──────────────┘  └──────────────┘  └──────────────┘  └──────────┘ │
└──────────────────────────────────────────────────────────────────────┘
```

Services Reference

The following service names are used consistently across the codebase and should appear in user stories when relevant.

Service	Responsibility	Technology

Auth Service	Sign-up, login, MFA, session management, proxy access grants	AWS Cognito + Lambda
Appointment Service	Book, cancel, reschedule slots; waitlist; Epic sync	Lambda + PostgreSQL 15
Messaging Service	Async patient-clinician messaging, attachments, urgent escalation	Lambda + PostgreSQL 15 + S3
FHIR Adapter	Bi-directional HL7 FHIR R4 bridge to Epic EHR; lab/radiology polling	Lambda + ElastiCache (Redis)
Notification Service	SMS (Twilio), email (SendGrid), push (FCM/APNs) dispatch	Lambda
Telehealth Service	Waiting room state, Doxy.me session lifecycle, recording consent	Lambda + DynamoDB
Prescription Service	Repeat request submission, status polling from Epic, reminder scheduling	Lambda + DynamoDB
Payment Service	Stripe co-payment initiation, receipt, reconciliation	Lambda
Audit Service	Append-only PHI access log (HIPAA §164.312), retained 7 years	Lambda + DynamoDB Streams + S3
File Store	Encrypted attachment storage, pre-signed URL generation (5 min TTL)	S3 (SSE-KMS) + Lambda

Tech Stack

Frontend

- **Framework**: React 18 (functional components, hooks)
- **Build tool**: Vite 5, TypeScript 5.x strict mode
- **Styling**: Tailwind CSS 3 + shadcn/ui component library
- **State management**: Zustand (global), React Query v5 (server state / cache)
- **Forms**: React Hook Form + Zod schema validation
- **PWA**: Workbox (offline appointment list, read-only record cache)
- **Accessibility**: axe-core integrated in CI; WCAG 2.1 AA enforced by Storybook a11y addon

Backend

- **Runtime**: Node.js 20 LTS on AWS Lambda (arm64 Graviton)
- **API style**: REST (public-facing) + GraphQL subscriptions (real-time inbox badge)
- **Auth**: JWT RS256 (Cognito User Pools); PKCE OAuth 2.0 for mobile
- **Database**: Amazon RDS PostgreSQL 15 (transactional data); DynamoDB (session, audit, telehealth state)
- **Cache**: ElastiCache (Redis 7) — FHIR response cache, appointment slot cache (TTL 60 s)
- **Queue / events**: AWS EventBridge (domain events); SQS FIFO (notification dispatch)
- **File storage**: S3 with SSE-KMS; pre-signed URLs for upload and download
- **Search**: (Phase 2) Amazon OpenSearch for clinical note full-text search

Infrastructure & DevOps

- **Cloud**: AWS (primary); eu-west-1 for EU patient data (GDPR residency)
- **IaC**: AWS CDK v2 (TypeScript)
- **Container**: Docker (Lambda container images); ECR repository
- **CI/CD**: GitHub Actions — lint → test → build → deploy (staging auto, prod manual approval)
- **Monitoring**: AWS CloudWatch + X-Ray tracing; PagerDuty on-call integration
- **Secrets**: AWS Secrets Manager (API keys, DB passwords); no secrets in environment variables

Security & Compliance Controls

- **Encryption at rest**: AES-256 via SSE-KMS on all S3 buckets and RDS snapshots
- **Encryption in transit**: TLS 1.3 enforced at API Gateway and internal VPC traffic
- **PHI tokenisation**: Patient identifiers stored as MRN tokens; plain MRN only in the FHIR Adapter boundary
- **Audit trail**: Every PHI read/write event emitted to Audit Service via EventBridge; immutable DynamoDB → S3 Glacier archive
- **Penetration testing**: Annual third-party pen test; quarterly DAST scan via OWASP ZAP in CI
- **HIPAA BAA**: Signed with AWS, Twilio, SendGrid, Doxy.me, Stripe

Integration Details

Epic EHR ↔ FHIR Adapter

- Protocol: HL7 FHIR R4 over HTTPS
- Authentication: OAuth 2.0 SMART on FHIR (backend services flow)
- Key FHIR resources used: `Patient`, `Appointment`, `MedicationRequest`, `DiagnosticReport`, `Observation`, `DocumentReference`, `Communication`
- Polling cadence: lab results every 15 min; radiology PDFs every 30 min
- Write-back: appointment cancellations, prescription requests, message threads (stored as `Communication` resources)

Doxy.me (Telehealth)

- Integration: iframe embed + postMessage API for session lifecycle events
- Session token generated server-side by Telehealth Service; valid for 60 minutes
- Recording: opt-in consent captured before session; recordings stored in S3 with 90-day retention

Stripe (Payments)

- Outpatient co-payments only (inpatient billing handled separately by Epic)
- Payment Intent API; no card data touches HealthConnect servers (PCI DSS SAQ-A)
- Webhook events: `payment_intent.succeeded`, `payment_intent.payment_failed`

Twilio / SendGrid (Notifications)

- Twilio: appointment reminders (SMS, 24 h + 2 h before), urgent message alerts
- SendGrid: transactional emails — booking confirmations, lab result notifications, password reset
- All communications respect patient preference flags stored in Appointment Service

Non-Functional Requirements

Category	Requirement
Availability	99.9% uptime SLA (excluding planned maintenance windows)

Latency	p95 API response < 400 ms; FHIR Adapter write-back < 2 s
Scalability	Auto-scaling Lambda; designed for 10× peak (seasonal flu, COVID surge)
Data retention	Clinical records: 10 years minimum; audit logs: 7 years; session logs: 90 days
RTO / RPO	RTO 4 h, RPO 1 h (RDS Multi-AZ + automated backups every hour)
Test coverage	Unit ≥ 80%; integration ≥ 60%; E2E smoke tests on every deploy